



Mobile Application Testing

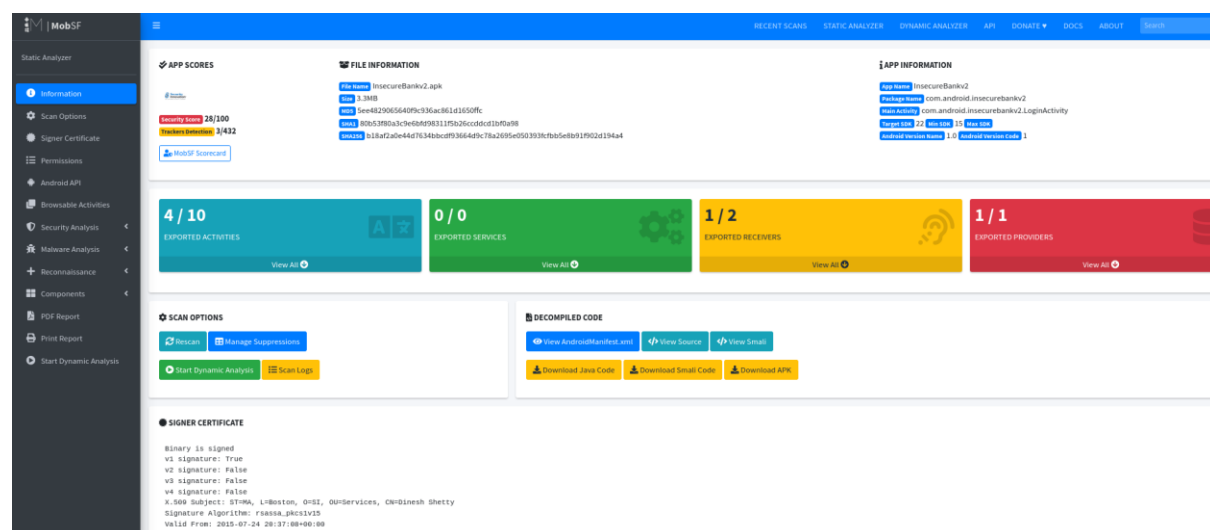
Overview

This report documents the findings from a structured mobile application security testing lab. The engagement covered three core activities: static analysis of an Android APK using MobSF to identify insecure data storage, dynamic instrumentation using Frida to hook application functions and bypass authentication controls, and Inter-Process Communication testing using Drozer to identify exposed components.

Target Application

- Application Name: **InsecureBankv2**
- File Type: APK
- Vulnerability Standard: OWASP Mobile Top 10

1. Upload test.apk to MobSF
2. MobSF automatically decompiles and scans the APK
3. Navigate to the Security Score and Findings sections
4. Export findings report as PDF from MobSF dashboard



Uddip Das



Frida Dynamic Testing — Authentication Bypass

Procedure: With frida-server running on the emulator, the LoginActivity class was targeted. The doesSuperAdminExists() and authentication validation functions were hooked using a Frida JavaScript script injected at runtime. The hook forced the return value to true regardless of credentials supplied.

Summary:

Frida was injected into InsecureBankv2 at runtime to hook the LoginActivity authentication function. A JavaScript hook forced the credential validation method to return true regardless of input. Supplying an incorrect password successfully authenticated into the application, confirming a complete authentication bypass through dynamic instrumentation with no knowledge of valid credentials required.

Remediation Recommendations

- Enable v2 and v3 APK signature schemes to fix the Janus vulnerability — v1 signing alone allows APK tampering.
- Set android:debuggable=false in production builds to prevent debugger attachment and memory dumping.
- Fix StrandHogg 2.0 on all four vulnerable activities by setting launchMode="singleInstance" and updating targetSdk to 29 or higher.
- Set android:exported=false on all sensitive activities, content providers, and broadcast receivers to block unauthorised access from third-party apps.
- Remove all hardcoded secrets and embedded credentials from the APK — move everything to a secure server-side vault.
- Set android:allowBackup=false to prevent full app data extraction via ADB.
- Raise minSdk to API 29 to ensure the app only runs on actively patched Android versions.
- Remove Google AdMob, Analytics, and Tag Manager trackers — inappropriate in any banking application.
- Implement root detection and runtime integrity checks to prevent Frida-based authentication bypass in production.